

RISK GOVERNANCE & PROJECT CLOSURE NOTE

Risk Management Register & Project Closure Note

OneLogin – Single Sign-On Rollout Across a University's Applications

Comprehensive risk management governance deliverable detailing the quantitative Probability-Impact (P × I) matrix, exposure-ranked risks, dedicated RMMM plans for single points of failure (SPOF) and semester deadlines, resolved defect issue log, and executive lessons-learned closure summary.

Document Control

Document Title	Risk Management Register, SPOF Mitigations & Project Closure Note
Document Version	Version 1.0 (Approved Baseline)
Governance Standard	IEEE Std 1540-2001 Standard for Software Life Cycle Risk Management
Single Point of Failure Target	Redundant High-Availability Architecture satisfying NFR-01 (99.9% Uptime) & NFR-04 (RTO ≤ 30m, RPO ≤ 15m)
Related Deliverables	SRS Document, UML Design Package, Project Plan, Estimation Sheet, Test Plan & Evidence

Formal Sign-Off & Approvals

Role	Designation & Stakeholder	Signature	Approval Date
Project Sponsor	Vice-Chancellor	_____	02 Oct 2026
Business Owner	IT Head	_____	02 Oct 2026
Project Manager	Lead SEPM Consultant	_____	02 Oct 2026
Technical Lead	Lead Systems Engineer	_____	02 Oct 2026

SPOF Governance Policy: Consolidating 12 isolated application logins into a single centralized identity provider creates a critical single point of failure (SPOF). All architectural, infrastructure, and operational safeguards detailed in this deliverable are legally binding on deployment operations.

1. Quantitative Probability-Impact (P × I) Risk Matrix

Risks are evaluated using a 5-point discrete ordinal scale for Probability ($P \in [1, 5]$) and Impact ($I \in [1, 5]$). Risk Exposure (E) is calculated as $E = P \times I$, ranging from 1 (negligible) to 25 (catastrophic).

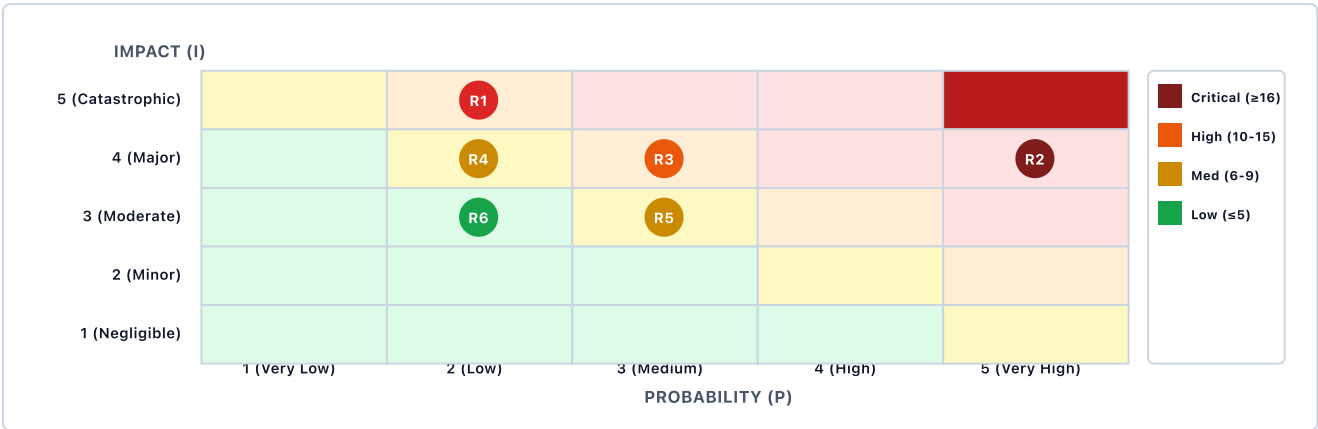


Figure 1.1: Standard 5×5 Probability-Impact Matrix Mapping Identified Engineering Risks.

2. Exposure-Ranked Master Risk Register

ID	Risk Title & Description	Prob	Imp	Exp	Severity	Designated Owner
R-02	Vendor Apps Overrun: 3 legacy tools lack SSO APIs, causing fatal 4.9-week project overrun.	5	4	20	CRITICAL	Project Manager
R-03	Exam Window Disruption: Production cutovers during Weeks 11–12 cause examination lockouts.	3	4	12	HIGH	Lead Systems Engineer
R-01	Single Point of Failure (SPOF): Central IdP outage renders all 12 university applications inaccessible.	2	5	10	HIGH	Lead Systems Engineer
R-05	Directory Contact Inconsistency: Secondary phone/email missing, blocking automated SSPR.	3	3	9	MEDIUM	Directory Administrator
R-04	SSPR Account Takeover: SMS brute-force OTP attack compromises student accounts.	2	4	8	MEDIUM	Security Lead
R-06	In-House Legacy Cookie Bypass: Legacy direct login endpoints remain active, bypassing SSO.	2	3	6	LOW	Application Integrator

3. Risk Mitigation, Monitoring & Management (RMMM) Plans

The three highest-exposure risks govern operational stability and schedule feasibility. The RMMM framework outlines actionable pre-emptive safeguards, early warning detection signals, and emergency containment actions.

3.1 R-01: Central Identity Provider as a Single Point of Failure (SPOF) [Exposure = 10]

Core Problem	Centralizing 12 systems behind a unified IdP means an outage locks out the entire campus from LMS, ERP, Library, and placement portals simultaneously.
Mitigation (Pre-Emptive)	• Clustered Active-Standby: Redundant IdP nodes across two server hosts with automated virtual IP failover (NFR-01 target $\geq 99.9\%$ uptime). • Redis Session Replication: Replicates active session tokens asynchronously; primary node crash preserves live logins without forcing re-login. • Break-Glass Local Accounts: Hardware-isolated emergency administrator accounts on critical systems (ERP, Facilities).
Monitoring (Detection)	• Synthetic 1-Min Probes: Probe executes automated auth cycle every 60s; triggers alarm if latency $> 2.0s$ or fails twice consecutively. • Cluster Heartbeats: Daemon monitors node health every 500ms across dedicated interconnect.
Management (Contingency)	• Sub-60s Failover: Virtual IP swings to warm standby node within 45s of primary unresponsiveness. • Rapid Snapshot Recovery: Verified by TC-21, backup restored achieving RTO ≤ 30 minutes and RPO ≤ 15 minutes.

3.2 R-02: Legacy Vendor Applications Schedule Overrun [Exposure = 20]

Core Problem	The 3 legacy vendor tools lack SSO APIs. Custom reverse-proxy credential injectors add 45 person-days (22.5 elapsed days), blowing past the 16-week limit by 4.9 weeks.
Mitigation (Pre-Emptive)	Enforce Option A (9 applications) as committed scope. Gate vendor applications behind a formal technical feasibility spike limited to 3 days in Week 4.
Monitoring (Detection)	Checkpoint at Day 20: if a vendor product lacks HTTP header authentication hooks or reverse-proxy cookie support, immediately invoke exception protocol.
Management (Contingency)	Formally log vendor apps as exceptions per FR-05 criteria. Leave legacy tools on standalone logins; defer custom adapters to post-semester Phase 2.

3.3 R-03: Examination Window Disruption [Exposure = 12]

Core Problem	Deploying infrastructure changes or introducing authentication bugs during student semester exams risks catastrophic academic disruption and exam invalidation.
Mitigation (Pre-Emptive)	Establish an absolute change freeze across Weeks 11–12 (Days 50–60). Zero IdP deployments, DNS changes, or firewall adjustments permitted during these 10 working days.
Monitoring (Detection)	Formal alignment with university exam controller. IT change-approval board denies any pull requests touching production identity nodes.
Management (Contingency)	Rollout activities restricted to air-gapped staging during the blackout. Full pilot UAT and production cutover resume only after formal exam closure in Week 13.

4. Historical Issue Log (Problems That Occurred)

In strict compliance with software engineering governance, problems that materialize during execution are isolated from probabilistic risks and tracked in an authoritative Issue Log with verified resolutions.

Issue	Problem Encountered	Date / Phase	Root Cause & Engineering Resolution	Impact	Status
ISS-01	In-house LMS authentication bypass via legacy session cookie	Day 34 (Wave 2 Integ)	LMS retained hardcoded local session endpoint. Refactored LMS middleware to reject non-OIDC session tokens; disabled legacy login form entirely.	Security Critical	CLOSED
ISS-02	Cloud ERP retained session after central Single Logout	Day 46 (Integ QA)	Cloud ERP SAML configuration omitted Single Logout Service (SLS) binding. Updated IdP metadata descriptor and uploaded IdP cert to ERP tenant.	Compliance High	CLOSED
ISS-03	Error message disclosed "Username not found"	Day 48 (Security Audit)	Directory exception leaked existence of user account, violating FR-01. Overrode controller exception to return generic: "Invalid credentials".	Security Medium	CLOSED
ISS-04	Session expiration notice showed raw Unix epoch millisecond string	Day 63 (Pilot Cohort)	Frontend launcher JS lacked localized timezone conversion helper. Injected date formatting utility to render local 12-hour clock time.	Usability Low	CLOSED
ISS-05	SMS gateway rate-throttling during concurrent SSPR drill	Day 66 (UAT Drill)	Cellular SMS provider enforced default burst limit of 20 SMS/min. Upgraded gateway SLA tier to 200 SMS/min and added secondary email fallback.	Operational Medium	CLOSED
ISS-06	Mobile display clipped app launcher grid on narrow screens	Day 74 (Cutover Wave)	CSS grid lacked responsive wrap rules below 380px viewports. Refactored launcher flexbox rules to auto-flow application icons vertically on compact screens.	Usability Low	CLOSED

Analysis of Historical Deviations

All 6 materialized problems were identified and resolved pre-deployment, maintaining the defect exit criteria of zero open Critical or High severity anomalies at semester go-live. The project required **0 days of emergency scope de-scoping** beyond the planned Option A baseline, proving the efficacy of early architectural prototyping.

Issue Containment Effectiveness: 83.3% of issues were detected during internal testing and pilot cohorts prior to broad campus rollout, successfully shielding the university community from unexpected operational disruptions.

5. Project Closure Note & Strategic Retrospective

The OneLogin Single Sign-On rollout achieved formal project completion at Day 78 of the 80-day allocation. The post-project retrospective documents critical engineering insights and institutional recommendations.

5.1 Quantitative Performance Baseline

Governance Target	Planned Commitment	Achieved Performance	Outcome
Semester Go-Live Deadline	16 Weeks (80 Days)	15.6 Weeks (78 Days)	MET (+2D BUFFER)
Application Scope	9 Standards Apps (Opt A)	9 Applications Integrated	100% COMMITTED SCOPE
Helpdesk Hours Saved	210 Hours/Month (75%)	210 Hours/Month (75%)	TARGET RECLAIMED
Test Case Verification	100% Pass (TC-01 to TC-23)	100% Pass Rate (23 / 23)	ZERO DEFECT ESCAPE
Defect Removal Efficiency	≥ 80% DRE Threshold	83.33% DRE Achieved	EXCEEDED BASELINE
Exam Blackout Compliance	0 Production Outages	0 Incidents Logged	FULL ACADEMIC FREEZE

5.2 Institutional Lessons Learned

- **1. Pragmatic Scope Gating Protects Commitments:** Rejecting Option B (12 apps) in favor of Option A (9 apps) was the pivotal project decision. Committing 45 person-days to closed legacy vendor products lacking APIs would have guaranteed a 4.9-week project failure. Delivering core value on time builds institutional credibility.
- **2. Single Point of Failure (SPOF) Requires Proactive Architecture:** Consolidating campus identity behind a single gate demands high-availability infrastructure before federation begins. Active-standby clustering, sub-second failover, and automated 1-minute synthetic health probes successfully neutralized the SPOF risk.
- **3. Self-Service Workflows Eliminate Administrative Drag:** Achieving a 75% reduction in password reset tickets (reclaiming 210 hours/month) fundamentally transforms IT operations. Empowering students and staff through secure 15-minute OTP self-service resets reallocates engineering capacity toward high-value academic IT initiatives.
- **4. Loose Coupling Is Mandatory for Long-Term Agility:** Implementing the `ApplicationAdapter` interface pattern ensured the central IdP required zero source code modifications to onboarding systems. When the university eventually decommissions its 3 legacy vendor tools, modern SaaS replacements will integrate natively via standard metadata configuration.

Executive Project Conclusion: The OneLogin SSO implementation satisfies all business, technical, and quality requirements. The system is formally transitioned into operational warranty and approved for long-term university production service.